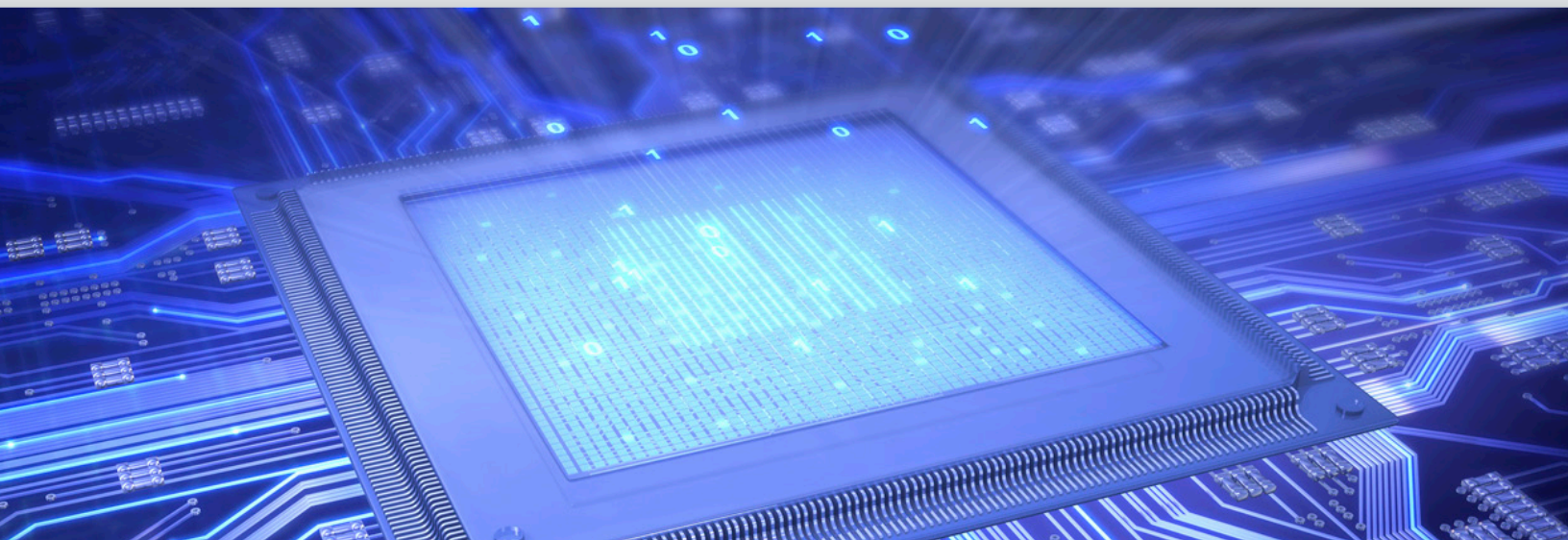




Happy Birthday, Mobile Malware!

The World's First Mobile Malware Celebrates Its 10th Birthday

2014 marks the 10th anniversary of Cabir, the world's first mobile phone malware. To mark this occasion, join Fortinet's FortiGuard Labs in taking a stroll down memory lane to examine the evolution and significance of mobile threats during the last 10 years.

Introduction

From Cabir to FakeDefend, the last decade has seen the number of mobile malware explode. In 2013, Fortinet's FortiGuard Labs has seen more than 1,300 new malicious applications per day and is currently tracking more than 300 Android malware families and more than 400,000 malicious Android applications.

Besides the sheer growth in numbers, another important trend to note is that mobile malware has followed the same evolution as PC malware, but at a much faster pace. The widespread adoption of smartphones--and the fact that they can easily access a payment system (premium rate phone numbers)--makes them easy targets that can quickly generate money once infected. Furthermore, they have capabilities such as geo-location, microphones, embedded GPS and cameras, all of which enable a particularly intrusive level of spying on their owners. Like PC malware, mobile malware quickly evolved into an effective and efficient way of generating a cash stream, while supporting a wide range of business models.

In the following chronology, FortiGuard Labs looks at the most significant mobile malware over the last 10 years and explains their role in the evolution of threats.

2004: The First Attempt!

Cabir was the world's first mobile worm. Designed to infect the Nokia Series 60, its attack resulted in the word "Caribe" appearing on the screen of infected phones. The worm then spread itself by seeking other devices (phones, printers, game consoles...) within close proximity by using the phone's Bluetooth capability.

"Experts believe that the worm was developed by the hacker group called 29A as 'proof of concept' due to its relatively inoffensive character," said Axelle Apvrille, senior mobile anti-virus researcher with Fortinet's FortiGuard Labs.

2005: Adding MMS to the Mix

CommWarrior, discovered in 2005, picked up where Cabir left off by adding the ability to propagate itself using both Bluetooth and MMS. Once installed on the device, CommWarrior would access the infected phone's contact file and send itself via the carrier's MMS service to each contact. The use of MMS as a propagation method introduced an economic aspect; for each MMS message sent, phone owners would incur a charge from their carrier. In fact, some operators have stated that up to 3.5 percent of their traffic was sourced to CommWarrior, and eventually agreed to reimburse the victims.

The virus, which also targeted the Symbian 60 platform, has been reported in more than 18 countries across Europe, Asia and North America. Altogether, the mobile worm infected more than 115,000 mobile devices and sent more than 450,000 MMS messages without the victims' knowledge, illuminating for the first time that a mobile worm could propagate as quickly as a PC worm.

"At the time, Symbian was the most popular smartphone platform with tens of millions users around the world," Apvrille continued. "However, the objective behind CommWarrior was to propagate itself as widely as possible and not to profit from the charges incurred through the MMS messages."

2006: Following the Money

After the demonstrated successes of Cabir and

CommWarrior, the security community detected a Trojan called RedBrowser touting several key differences from its predecessors. The first was that it was designed to infect a phone via the Java 2 Micro Edition (J2ME) platform. The Trojan would present itself as an application to make browsing Wireless Application Protocol (WAP) websites easier. By targeting the universally supported Java platform rather than the device's operating system, the Trojan's developers were able to target a much larger audience, regardless of the phone's manufacturer or operating system.

The second, and perhaps more important difference, is that the Trojan was specifically designed to leverage premium rate SMS services. The phone's owner would typically be charged approximately \$5 per SMS -- another step toward the use of mobile malware as a means of generating a cash stream.

Apvrille added, "Until the emergence of RedBrowser, the security community believed it was impossible that a single piece of malware could infect a wide range of mobile phones with different operating systems. The use of J2ME as an attack vector was an important milestone during this period, as was the use of SMS as a cash generating mechanism."

2007-2008: A Period of Transition

Despite stagnation in the evolution of mobile threats during this two-year period, there was an increase in the number of malware that accessed premium rate services without the device owner's knowledge.

2009: The Introduction of the Mobile Botnet

In early 2009, Fortinet discovered Yxes (anagram of "Sexy"), a piece of malware behind the seemingly legitimate "Sexy View" application. Yxes also had the distinction of being a Symbian certified application, which took advantage of a quirk within the Symbian ecosystem that allowed developers to "sign off" applications themselves.

Once infected, the victim's mobile phone forwards its address book to a central server. The server then forwards a SMS containing a URL to each of the contacts. Victims who click on the link in the message download and install a copy of the

malware, and the process is repeated.

The spread of Yxes was largely limited to Asia, where it infected at least 100,000 devices in 2009.

“Yxes was another turning point in the evolution of mobile malware for several reasons,” Apvrille said. “First, it is considered the first malware targeting the Symbian 9 operation system. Secondly, it was the first malware to send a SMS and access the Internet without the mobile user’s knowledge, a development deemed a technological innovation in malware. Finally, and perhaps most importantly, the hybrid model that it used to self-propagate and communicate with a remote server, gave antivirus analysts a reason to fear that this was perhaps a forewarning for a new kind of virus -- botnets on mobile phones. Future events would later validate that perception.”

2010: The Industrial Age of Mobile Malware

2010 marked a major milestone in the history of mobile malware: the transition from geographically localized individuals or small groups to large-scale, organized cybercriminals operating on a worldwide basis. This is the beginning of the “industrialization of mobile malware” in which attackers realized that mobile malware could easily bring them a lot of money, eliciting a decision to exploit the threats more intensely.

2010 was also the introduction of the first mobile malware derived from PC malware. Zitmo, Zeus in the Mobile, was the first known extension of Zeus, a highly virulent banking Trojan developed for the PC world. Working in conjunction with Zeus, Zitmo is leveraged by cybercriminals to bypass the use of SMS messages in online banking transactions, thus circumventing the security process.

There were other malware in the headlines well this year, most notably Geinimi. Geinimi was one of the first malware designed to attack the Android platform and use the infected phone as part of a mobile botnet. Once installed on the phone, it would communicate with a remote server and respond to a wide range of commands --such as installing or uninstalling applications--that allowed it to effectively take control of the phone.

“While the introduction of mobile malware for Android and mobile botnets were certainly significant events during 2010, they were overshadowed by the growing presence of organized cybercriminals who began to leverage the economic value of mobile malware,” Apvrille said.

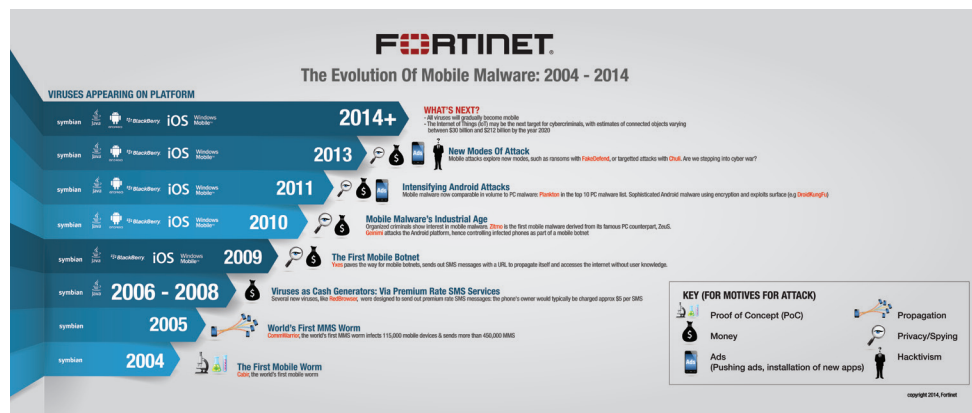
2011: Android, Android and Even More Android!

With attacks on Android platforms intensifying, more powerful malware began to emerge in 2011. DroidKungFu, for example, emerged with several unique characteristics, and even today is

considered one of the most technologically advanced viruses in existence. The malware included a well-known exploit to “root” or become an administrator of the phone – uDev or Rage

Against The Cage – giving it total control of the device and the ability to contact a command server. It was also able to evade detection by anti-virus software, the first battle in the ongoing war between the cybercriminals and the anti-virus development community. Like of most the viruses before it, DroidKungFu was generally available from unofficial third party app stores and forums in China.

Plankton also arrived on the scene in 2011 and is still one of the most widespread Android malware. Even on Google Play, the official Android apps store, Plankton appears in a large number of apps



as an aggressive version of adware, downloading unwanted ads to the phone, changing the homepage of the mobile browser or adding news shortcuts and bookmarks to the user's mobile phone.

"With Plankton, we're now playing in the big leagues! Plankton is one of the top 10 most common viruses across all categories, putting it in the same league as the top PC viruses," Apvrille added. "The days of mobile malware that lag behind their PC counterparts are over. Currently there are more than 5 million devices infected with Plankton alone."

2013: Game On – New Modes of Attack

2013 marked the arrival of FakeDefend, the first ransomware for Android mobile phones. Disguised as an antivirus, this malware works in a similar way to the fake antivirus on PCs. It locks the phone and requires the victim to pay a ransom (in the form of an exorbitantly high antivirus subscription fee, in this case) in order to retrieve the contents of the device. However, paying the ransom does nothing to repair the phone, which must be reset to factory settings in order to restore functionality.

It was also in 2013 that Chuli first appeared. Chuli malware was considered the first targeted attack on the Android platform. Cybercriminals behind the attack leveraged the email account of an activist at the World Uyghur Conference, held March 11-13, 2013 in Geneva, to target the accounts of other Tibetan Human Rights activists and advocates. The emails sent from the hacked account included Chuli as an attachment, a piece of malware designed to collect data such as incoming SMS, SIM card and phone contacts, location information, and recordings of victims' phone calls. The captured information was then sent to a remote server.

"2013 can be considered the year mobile attacks 'turned pro,'" said Apvrille. "Increasingly targeted and sophisticated, malware like FakeDefend or Chuli are examples of attacks comparable to those we know of today in the PC world."

Moreover, it's perfectly reasonable to ask whether an attack like Chuli is ushering us into an era of mobile cyber-warfare and the beginning of the potential involvements with governments and other national organizations."

What's Next?

With cybercrime, it is always difficult to predict what will happen next year and even more so over the next 10 years. The landscape of mobile threats has changed dramatically over the past decade and the cybercriminal community continues to find new and increasingly ingenious ways of using these attacks for one sole purpose – making money.

However, with the explosion of smartphones and other mobile technologies, a reasonable prediction is the convergence of mobile and PC malware. As everything becomes "mobile," all malware will then be "mobile."

Beyond mobile devices, the most likely future target for cybercriminals is the Internet of Things (IoT). While extremely difficult to forecast the number of connected objects on the market in the next five years, Gartner estimates 30 billion objects will be connected in 2020, while IDC estimates that market to be 212 billion. More and more manufacturers and service providers are capitalizing on the business opportunity presented by these objects, but it's reasonable to assume that security has not yet been taken into account in the development process of these new products. Will the IoT be "The Next Big Thing" for the cybercriminal?



GLOBAL HEADQUARTERS

Fortinet Inc.
1090 Kifer Road
Sunnyvale, CA 94086
United States
Tel: +1.408.235.7700
Fax: +1.408.235.7737
www.fortinet.com/sales

EMEA SALES OFFICE

120 rue Albert Caquot
06560, Sophia Antipolis,
France
Tel: +33.4.8987.0510
Fax: +33.4.8987.0501

APAC SALES OFFICE

300 Beach Road 20-01
The Concourse
Singapore 199555
Tel: +65.6513.3730
Fax: +65.6223.6784

LATIN AMERICA SALES OFFICE

Prol. Paseo de la Reforma 115 Int. 702
Col. Lomas de Santa Fe,
C.P. 01219
Del. Álvaro Obregón
México D.F.
Tel: 011-52-(55) 5524-8480